

Phishing og menneskelig sårbarhet: hvorfor teknikken feiler når mennesket blir inngangsporten

Et utviklingsforslag for mastergrad i cybersikkerhet, med hovedfokus på sårbarhetsflaten mellom social engineering og menneskelig beslutningstaking - ikke bare tekniske kontroller.

Karina Sætersdal Nilssen · utkast oppdatert 27. august 2026 · status: retning valgt

Hvorfor denne retningen

Magefølelsen peker mot phishing - og det henger sammen med det du allerede har gravd i.

I samtaler, labber og oppgavearbeid har du sett det samme mønsteret: mange alvorlige hendelser starter ikke med «film-hacking», men med et menneske som klikker, stoler, skynder seg eller misforstår. Tekniske tiltak finnes, men angripere går fortsatt ofte via **tillit, hastverk og kognitiv overload**.

Det er nettopp **sårbarhetsaspektet mellom phishing og mennesket** du vil fordype deg i: ikke bare hva phishing er, men *hvorfor* det fortsatt fungerer, *hvem* som er mest sårbare, og *hva* som faktisk reduserer risiko i praksis.

Human factors

Social engineering

Phishing

Beslutning under press

Awareness vs. atferd

AI-forsterket svindel

Arbeidstittel

Norsk: Phishing og menneskelig sårbarhet: en studie av hvorfor brukere fortsatt faller for social engineering

Engelsk: Phishing and Human Vulnerability: Understanding Why Users Remain the Weakest Link in the Attack Chain

Endelig tittel kan strammes inn når metode og datagrunnlag er avklart med veileder.

Problemstilling

Organisasjoner investerer i sikkerhetsteknologi, opplæring og policy - likevel er phishing fortsatt en av de vanligste og mest effektive inngangsportene til større angrep.

Dette tyder på at problemet ikke bare er teknisk, men ligger i **møtet mellom angrep og menneskelig adferd**: hvordan vi vurderer avsendere, håndterer autoritet og hastverk, og reagerer under usikkerhet. Masteroppgaven bør derfor undersøke denne sårbarhetsflaten systematisk.

Kjerneidé: Phishing er ikke bare et «IT-problem». Det er et angrep rettet mot hvordan mennesker tenker, føler og handler under press.

Tidligere retninger vi har luftet

Du har vurdert flere temaer. Phishing-retningen binder flere av dem sammen uten å bli for bred.

VALGT HOVEDRETNING

Phishing og menneskelig sårbarhet

Fokus på hvorfor brukere klikker, stoler og handler feil - og hva som faktisk hjelper.

STØTTEPERSPEKTIV

Angrepskjede etter phishing

Session hijacking, kontoovertakelse, datatyveri og ransomware som mulig konsekvenskapittel.

STØTTEPERSPEKTIV

Privacy / cookies / tredjeparter

Relevant som bakgrunn for tillit, sporingsmekanismer og brukerforståelse - ikke hovedfokus.

AVVIST SOM HOVEDFOKUS

Ransomware alene

Viktig, men for ofte «sent i kjeden». Phishing gir et bedre utgangspunkt for human-factor-analyse.

Forskningsspørsmål (utkast)

1. **Hvorfor** fungerer phishing fortsatt, til tross for bevisstgjøring og tekniske tiltak?
2. **Hvilke menneskelige og kontekstuelle faktorer** (hastverk, autoritet, stress, digital kompetanse, arbeidsbelastning) øker sannsynligheten for at brukere klikker eller oppgir informasjon?
3. **Hvilke tiltak** (opplæring, prosedyrer, tekniske kontroller, rapporteringskultur) oppleves som mest effektive for å redusere risiko i praksis?
4. **Hvordan endrer AI-forsterket phishing** (mer personlige lurer, bedre språk, impersonering) den menneskelige sårbarhetsflaten?

Disse kan strammes til 2-3 hovedspørsmål avhengig av om du velger kvalitativ, kvantitativ eller mixed methods.

Teoretisk ramme (forslag)

Teori / perspektiv	Hvorfor det er relevant
Human factors / human-computer interaction	Forklarer hvordan design, kognitiv belastning og brukeratferd skaper sårbarhet.
Protection Motivation Theory	Ser på trusselvurdering, opplevd alvor og opplevd egen effekt - hvorfor folk likevel handler risikabelt.
Social engineering / persuasion	Autoritet, hastverk, frykt, gjengjeldelse og likhet - klassiske psykologiske pressmidler i phishing.
Security culture og organisatorisk læring	Om folk tør å spørre, rapportere og stoppe opp uten å føle seg dumme.
Human-as-the-weakest-link (kritisk)	Brukes som utgangspunkt, men bør utfordres: kanskje systemene er designet for å feile menneskelig.

Mulig metode

Du trenger ikke låse metode nå, men disse tre stiene er realistiske for master:

Alternativ A: Kvalitativ (sterk for «hvorfor»)

- Intervjuer med ansatte/studenter/IT-ansvarlige
- Tema: nære møter med phishing, hva de så, hva de tenkte, hva de gjorde
- Godt for magesfølelses-spolet ditt: menneskelig beslutning og skam/tillit

Alternativ B: Mixed methods (ofte best for master)

- Kort spørreundersøkelse om erfaring, tillit og sikkerhetsatferd
- Deretter dybdeintervjuer med utvalgte respondenter
- Eventuelt simulert phishing-test i kontrollert miljø (krever etikk/godkjenning)

Alternativ C: Case-studie

- Én organisasjon eller ett domene (f.eks. høyere utdanning / offentlig sektor)
- Analyse av policy, awareness-program, hendelser og brukeropplevelse

Anbefaling nå: start med *Alternativ B* som arbeidshypotese. Den gir både bredde og dybde, og lar deg snakke om både menneskelig svakhet og hva som faktisk hjelper.

Hva du kan hevde i oppgaven (tyngde uten overdrivelse)

- Phishing er fortsatt en av de viktigste inngangsportene til større angrep.
- Problemet er ofte et **menneske-system-problem**, ikke bare brukerfeil.
- AI gjør lurer mer troverdige, men endrer ikke grunnleggende psykologi - den forsterker den.
- Awareness alene er sjelden nok; kultur, design og prosess må støtte opp.
- Det er forskjell på «vite om phishing» og «klare å stoppe seg selv i øyeblikket».

Avgrensing

- **Inkludere:** e-post, SMS/smishing, vishing i den grad det henger sammen med phishing-logikk.
- **Kan nevnes, men ikke dominere:** ransomware, session hijacking, GDPR/cookies.
- **Ekskludere som hovedfokus:** dyp teknisk malware-analyse, pentesting, kryptografi.
- **Geografi:** Norge / nordisk kontekst, med internasjonal litteratur som rammeverk.

Foreslått kapittelstruktur

1. Innledning og problemstilling
2. Bakgrunn: phishing som inngangsport i moderne trusselbilde
3. Teoretisk rammeverk: menneskelig sårbarhet og social engineering
4. Metode
5. Funn
6. Diskusjon: hvorfor mennesket fortsatt er sårbart
7. Konklusjon og anbefalinger for praksis

Startlitteratur

- NSM - varsler og veiledning om phishing og social engineering
- ENISA Threat Landscape (sosial engineering og menneskelig risiko)
- CISA - phishing og rapporteringsråd
- Hadnagy, C. - *Social Engineering: The Science of Human Hacking*
- Conteh & Schmick - Protection Motivation Theory i cybersikkerhet
- Recent rapporter om AI-assistert phishing (Halcyon, Trend Micro, Microsoft Digital Defense)

Neste steg for deg

1. Book veiledning og ta med dette dokumentet som utgangspunkt.
2. Velg om du vil gå for intervjuer, survey eller case - helst innen 2-3 uker.
3. Skriv 1 side «problem statement» på engelsk til veileder.
4. Lag en enkel litteraturliste med 10-15 kilder.
5. Bestem population: studenter, ansatte, offentlig sektor eller generell befolkning.
6. Avklar etikk: behov for NSD/sikker behandling hvis sensitive erfaringer/intervjuer.

Internt arbeidsdokument for masterplanlegging. Kan videreutvikles til formelt prospekt etter veiledermøte.